

Botium Toys

Cybersecurity Internal Security Audit

Portfolio Project

Assessment Type: Internal security audit exercise
Organization: Botium Toys (fictional organization)
Framework Context: NIST Cybersecurity Framework

This portfolio project documents the assessment of cybersecurity controls, compliance practices, risks, and recommended improvements for a fictional toy company.

1. Executive Summary

This project presents an internal cybersecurity audit of Botium Toys. The audit scope covers the organization's entire security program, including assets, internal processes, controls, and compliance best practices. The primary goal is to identify existing security controls and determine which controls and compliance practices require improvement.

The risk assessment identifies inadequate asset management and gaps in security controls and compliance practices. The documented overall risk score is 8 out of 10, described in the source material as fairly high.

The assessment identified important gaps involving least privilege, separation of duties, encryption, intrusion detection, backups, disaster recovery, password management, asset classification, and protection of sensitive customer information.

2. Audit Scope and Goals

Scope

The scope is the entire security program at Botium Toys. This includes all assets as well as internal processes and procedures related to implementing controls and compliance best practices.

Goals

Assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices need to be implemented to improve Botium Toys' security posture.

Key Assets

On-premises equipment; employee devices; storefront products and warehouse inventory; accounting, telecommunications, database, security, ecommerce, and inventory-management systems; internet access; internal network; data retention and storage; and legacy systems requiring human monitoring.

3. Risk Assessment

Risk Description: Botium Toys has inadequate management of assets and does not have all necessary controls in place. The organization may also not be fully compliant with applicable U.S. and international regulations and standards.

Risk Score: 8/10 — fairly high.

Asset Impact: The potential impact from loss of an asset is rated medium because the IT department does not know which assets would be at risk. The risk to assets or potential regulatory fines is rated high in the source assessment.

NIST CSF Identify: The organization needs to identify and classify assets and determine the potential impact of asset loss on business continuity.

4. Controls Assessment

Control	Status	Assessment
Least Privilege	NO	Not implemented.
Disaster Recovery Plans	NO	No plans currently in place.
Password Policies	YES*	Policy exists, but requirements are weak/outdated.
Separation of Duties	NO	Not implemented.
Firewall	YES	Firewall blocks traffic using defined security rules.
Intrusion Detection System (IDS)	NO	IDS has not been installed.
Backups	NO	No backups of critical data.

Control	Status	Assessment
Antivirus Software	YES	Installed and regularly monitored.
Legacy-System Monitoring/Maintenance	YES*	Performed, but schedule and intervention methods are unclear.
Encryption	NO	Customer credit-card information is not encrypted.
Password Management System	NO	No centralized system.
Locks	YES	Physical location has sufficient locks.
CCTV Surveillance	YES	Up-to-date CCTV is in place.
Fire Detection/Prevention	YES	Functioning systems are in place.

*A Yes status means the control exists according to the source report; it does not mean the control is fully effective or compliant. Password policy requirements and legacy-system procedures require improvement.

5. Compliance Assessment

Framework / Best Practice	Status	Assessment
PCI DSS — Authorized access to cardholder data	NO	All employees have access to internally stored data and may be able to access cardholder data.
PCI DSS — Secure cardholder-data environment	NO	Existing controls are insufficient to establish the required secure environment.
PCI DSS — Encryption	NO	Encryption is not currently used for customer credit-card information.
PCI DSS — Secure password management	NO	Password policy is weak and there is no centralized password-management system.
GDPR — E.U. customer data privacy/security	NO	Broad internal access may expose customer PII/SPII.
GDPR — 72-hour breach notification	YES	A plan exists to notify E.U. customers within 72 hours.
GDPR — Data classification/inventory	NO	Asset identification and classification need improvement.
GDPR — Privacy policies/processes	YES	Privacy policies, procedures, and processes have been developed and enforced.
SOC — User access policies	NO	Least privilege and separation of duties are not implemented.
SOC — PII/SPII confidentiality	NO	All employees have access to internally stored data and may access PII/SPII.
SOC — Data integrity	YES	IT has implemented controls to ensure data integrity.
SOC — Data availability	YES	The source report states that availability controls have been integrated.

6. Key Security Findings

1. Broad data access — all employees have access to internally stored data and may be able to access cardholder data and customer PII/SPII.
2. Sensitive-data encryption gap — customer credit-card information is not encrypted when accepted, processed, transmitted, and stored locally.
3. Access-control gap — least privilege and separation of duties have not been implemented.
4. Detection gap — an intrusion detection system has not been installed.
5. Recovery gap — there are no disaster recovery plans or backups of critical data.
6. Password-management gap — the password policy is weak and there is no centralized password-management system.
7. Legacy-system process gap — legacy systems are monitored and maintained, but there is no regular schedule and intervention methods are unclear.

7. Recommendations

1. Implement least-privilege access based on job responsibilities.
2. Implement separation of duties for sensitive responsibilities.
3. Strengthen password-complexity requirements and enforce them consistently.
4. Deploy a centralized password-management system.
5. Encrypt sensitive customer and cardholder information.
6. Create and maintain backups of critical business data.
7. Develop and document a disaster-recovery plan.
8. Deploy an intrusion detection system.
9. Establish a regular schedule and documented procedures for legacy-system maintenance.
10. Create an accurate asset inventory and classify assets according to business impact.

11. Restrict access to customer PII/SPII and cardholder data to authorized personnel.

12. Continue maintaining physical controls such as locks, CCTV, and fire detection/prevention systems.

8. Control Categories Used

Administrative/Managerial controls address policies, procedures, employee responsibilities, and how the organization manages data. Technical controls include technologies such as firewalls, IDS/IPS, antivirus, and encryption.

Physical/Operational controls include locks, surveillance cameras, and other measures that limit physical access.

The source material also categorizes controls as Preventative, Corrective, Detective, and Deterrent. These controls work together to provide defense in depth.

9. Conclusion

The assessment shows that Botium Toys has several foundational controls in place, particularly around firewall protection, antivirus, physical security, CCTV, fire detection, data integrity, and E.U. breach notification planning. However, significant gaps remain in access control, encryption, detection, recovery, password management, asset classification, and protection of sensitive data. Addressing these areas would reduce identified risks and improve the organization's overall security posture.

Portfolio note: This document is an educational cybersecurity audit exercise based on the fictional Botium Toys organization. It does not represent an audit of a real company.